

Risk Management & Third-Party Vendor Risk

Meridian Health Partners

Company Snapshot

Meridian Health Partners is a telehealth provider serving patients across four states through video visits, a patient portal, and in-person intake at two clinic locations. The organization uses CarePath Cloud for electronic health record (EHR) hosting, ClaimLogic for insurance billing and claims processing, and TeleConnect Live to host video visits.

Meridian also contracts with QuickFix IT Support, a third-party helpdesk vendor whose technicians remotely manage and maintain clinician laptops, including software installs, patching, and troubleshooting. QuickFix's contract renewal review is underway.

Internal Audit & Interview Notes

These notes are drawn from a recent internal walkthrough and staff interviews. Not every note describes a risk in the same way — part of your job is to translate each one into a clear risk statement.

- "Several clinicians access the patient portal from personal phones and laptops; there's no mobile device management (MDM) enrollment requirement."**
- "Password policy requires 8 characters, but multi-factor authentication is optional — only about a third of staff have turned it on."**

- "The clinic's written incident response plan was last updated two years ago and has never been tested with a tabletop exercise."
- "Paper intake forms containing patient information are stored in an unlocked file room behind the reception desk; sign-in and access aren't logged."
- "ClaimLogic, the billing vendor, disclosed a minor security incident involving an internal phishing attempt last year; Meridian never followed up to confirm remediation."
- "QuickFix IT Support technicians have standing local administrator rights on every clinician laptop, and that access isn't reviewed or time-limited."
- "A staff newsletter article noted that healthcare has had the highest average data breach cost of any industry for multiple years running."

Part 1 — Risk Assessment & Risk Register

#	Risk description	Likelihood	Impact	Risk Level	Treatment Strategy	Owner
1	No MDM management	high	high	critical	Mitigate (implement MDM, and enforce policies)	CISO
2	Weak password requirement w/ no MFA requirement	med	high	critical	Mitigate (require more complex password, and set time limit)	IT manager

					on it)	
3	Untested, and out of date incident response plan	high	high	critical	Mitigate (test incident response plan)	CISO
4	Unsecure paper patient intake forms containing PHI	high	high	critical	Mitigate (secure file cabinet with PHI)	Clinic site manager
5	No follow-up, or plan to address known vulnerability (phishing)	med	high	critical	Accept (falls outside scope of Meridian)	CISO
6	Over provisioned support technicians without any controls	high	high	critical	Mitigate (implement ABAC control)	IT manager

Part 2 — Vendor Risk Evaluation

Step 1: Spot the Red Flags

Identify at least 4 specific red flags in the questionnaire responses. List them below.

- 1. No MFA, and apparently shared support login for remote access.
- 2. No defined incident response plan.
- 3. Overprovisioned access on client laptops.
- 4. No background checks for pre-hire for employees, and no training on data handling.

Step 2: Decision: Reject

Justification: Based on the questionnaire, this vendor would be rejected. They are light on securing data, and systems. They have no formal incident response plan. Access to systems is very vulnerable based on no MFA, and shared logins. They also give admin rights to all client

laptops increasing the attack surface. Also, there is no formal background checks of employees for pre-hire, and no formal training once hired.

Step 3: Contractual Protections

Protections	What it requires of the vendor
Better authentication and authorization	Require more complex passwords (with expirations), and implement MFA—no sharing of logins
Incident response plan	Have a formal incident response plan and test on a regular basis (every quarter), base it on a known standard like NIST CSF, or ISO IEC 27001
SLA	Lay out roles, and expectations of uptime, downtime, and incident response. Assign owner responsibilities
Background checks/training	Perform background checks on employees prior to hire, and implement training for new hires, as well as ongoing training in best practices in security.

Step 4: Ongoing Monitoring Plan

Propose how your group would monitor this vendor going forward. Address all three:

- 1. Review cadence — how often will you formally reassess this vendor?**
- 2. What you'll monitor — e.g., access logs, security ratings, updated attestations**
- 3. Access scope changes — what, if anything, should change about the vendor's current access?**

Monitoring plan: 1. Initially I would want to reassess this vendor every 45 days to ensure compliance, but after a year of compliance, every 90 days would be reasonable.

2. For this vendor, hopefully they have obtained a security certification such as ISO IEC 27001. I would also like to see their updated incident response plan, and be able to audit their security protocols, logs, incident reports, and policies. Check to see if they have had any security incidents recently, and if so, how they approached it.

3. For their access scope, they should be implementing MFA, and no longer sharing passwords, but also, importantly, they should be implementing RBAC, or ABAC to limit access of client laptops. This help mitigate one employee's credentials being compromised.

Part 3 — Executive Summary Memo

To: Chief Operating Officer, Meridian Health Partners

From: Daniel Ender

Date: 08/18/2026

Re: Risk and Vendor Review – Meridian Health Partners

There are 3 priority critical risks that this company faces:

- No MDM management of employee devices
- No up-to-date incident response plan
- Weak password policy with no MFA requirement/overprovisioned IT access (QuickFixIT)

These three risks pose a critical danger to the company. No centralized management of employee devices creates a vulnerability. If an employee's credentials, or device became compromised, then an attacker could laterally move through the company's data, potentially exposing sensitive patient PHI, and other PII. Incident response plans need to be updated often, and not having one that is up to date would create serious issues in mitigation, and containment in the event of a breach. Having more restrictive password policies reduces the attack surface of the company, and limits an attacker even if an employee's password became compromised. Also, the Quickfix IT vendor has too much access to our database which has sensitive information. They should be limited to just the access required to do their job.

-My overall recommendation on the vendor (QuickFixIT) is to reject them going forward. They themselves present an inherent risk by their poor security measures. With the access they currently have to our systems, and based on their current operating level, they could easily be compromised, and an attacker would have great access to our sensitive data. There are things that they could implement to improve this, but in their current form they are a liability to us, and our patients.

-For this company, I would recommend outsourcing the cybersecurity of this company, and other IT services to a vetted company with experience in handling PHI, and PII. Use a company that implements strong password complexity, MFA, is certified, and uses MDM.